IT Risk Management

ES234423 – 3 Credits
2025.2

Week 8: Understanding ISO 27001

Eko Wahyu Tyas Darmaningrat

tyas.darmaningrat@its.ac.id (082331106699)

INFORMATION SECURITY

MANAGEMENT SYSTEM

INTRODUCTION TO ISO 27001

What is it?

ISO/IEC 27001 is the internationally recognised standard for Information Security Management Systems (ISMS). It provides a systematic approach to managing sensitive information.

Who uses it?

Organisations of all sizes and sectors use ISO 27001 - from banks and hospitals to tech companies and government agencies - to protect information assets.

Why certify?

Certification demonstrates that an organisation has identified risks and put controls in place to protect confidential data, ensuring trust with clients and partners.

ISO 27001 KEY STRUCTURE

📐 PLAN

Establish ISMS context, define scope, perform risk assessment & risk treatment (Clause 4–6)

⚙️ DO

Implement & operate the ISMS, apply security controls from Annex A (Clause 7–8)

PDCA
Cycl

🔍 CHECK

Monitor, measure, analyse performance; conduct internal audits & management reviews (Clause 9)

🔄 ACT

Address nonconformities, take corrective actions, achieve continual improvement (Clause 10)

ANNEX A: CONTROL CATEGORIES (ISO 27001:2022)

A.5

Organisational Controls

37 controls

37

A.6

People Controls

8 controls

8

A.7

Physical Controls

14 controls

14

A.8

Technological Controls

34 controls

34

INDIVIDUAL CLASS ACTIVITY

Part A

Answer the following questions based on ISO 27001:2022.
Include the specific clause or control that supports your answer, and on which page you can find the information.
Don't forget to use the CA template!

Questions 1 – 15

PART A – Questions 1 to 5

Answer based on ISO 27001:2022

1 Apa definisi "information security" menurut ISO 27001:2022?

2 Sebutkan 3 properti utama keamanan informasi yang disebutkan dalam standar ISO 27001!

3 Apa yang dimaksud dengan "*Statement of Applicability* (SoA)" dan di klausul berapa hal ini dipersyaratkan?

4 Sebutkan tahapan proses penilaian risiko (*risk assessment*) yang harus dilakukan organisasi menurut Klausul 6.1.2!

5 Apa saja yang harus ditetapkan organisasi dalam kebijakan keamanan informasi menurut Klausul 5.2?

PART A – Questions 6 to 10

Answer based on ISO 27001:2022

6 Di klausul berapa ISO 27001 mensyaratkan organisasi untuk melakukan audit internal, dan seberapa sering audit tersebut harus dilakukan?

7 Apa perbedaan antara "*risk owner*" dan "*asset owner*" dalam konteks ISO 27001?

8 Sebutkan kategori kontrol dalam Annex A ISO 27001:2022 beserta jumlah kontrol di masing-masing kategori!

9 Apa yang dimaksud dengan "*continual improvement*" dalam ISO 27001 dan di klausul berapa hal ini diatur?

10 Menurut Klausul 7.5, dokumen apa saja yang wajib ada (*documented information*) dalam sebuah ISMS?

PART A – Questions 11 to 15

Answer based on ISO 27001:2022

11 Untuk memastikan bahwa hasilnya konsisten, valid, dan dapat dibandingkan *(comparable),* kriteria spesifik apa yang harus ditetapkan oleh suatu organisasi untuk melakukan penilaian risiko?

12 Dua faktor apa yang harus dinilai untuk setiap risiko yang teridentifikasi guna menentukan tingkat risiko akhir?

13 Siapa yang bertanggung jawab memberikan persetujuan akhir atas rencana penanganan risiko dan menerima risiko residual?

14 Dalam dua kondisi spesifik apa suatu organisasi harus melakukan penilaian risiko keamanan informasi setelah pengaturan awal?

15 Saat merencanakan pemantauan dan pengukuran, dua elemen inti ISMS (proses dan kontrol) apa yang harus dievaluasi efektivitasnya?

INDIVIDUAL CLASS ACTIVITY

Part B

Case Study Analysis – Apply ISO 27001 to Real Scenarios

Case 1 · Case 2 · Case 3

CASE 1: THE CARELESS EMPLOYEE AT A FINTECH STARTUP

SCENARIO

PT. FinansTech is a growing fintech startup in Surabaya that processes online loan applications. One day, a customer service employee accidentally sends a spreadsheet containing 500 customers' personal data (NIK, phone numbers, loan amounts) to the wrong email address; an external vendor who was not authorised to receive it. The incident was only discovered 3 days later when the vendor replied asking what to do with the file. The company has no formal procedure for handling such incidents, and employees have never received any security training.

Questions on next slide →

CASE 1 – Questions for Students

1

What ISO 27001 clause requires the organisation to plan and control operational processes to meet security requirements?

2

Which Annex A controls are most relevant to human error, information classification, and incident management?

3

What clause and control would require the company to establish an incident response procedure?

CASE 2: THE UNIVERSITY THAT NEVER REVIEWED ITS ACCESS RIGHTS

📋 SCENARIO

Universitas Maju Bersama has an academic information system storing student grades, financial records, and lecturer contracts. An IT audit reveals that 47 former employees, including resigned lecturers and graduated student workers, still have active login credentials. One ex-employee was found to have accessed the salary database twice in the past month. The university's rector claims there is an IT policy, but it has not been updated since 2019 and no one reviews user access periodically.

Questions on next slide →

CASE 2 – Questions for Students

1. Which ISO 27001 clause requires top management to establish, review, and maintain relevant policies?

2. What Annex A controls specifically address access rights management and user access reviews?

3. Which clause deals with evaluating the performance and effectiveness of the ISMS (including policy reviews)?

CASE 3: THE CLOUD MIGRATION WITHOUT A RISK ASSESSMENT

SCENARIO

PT. LogistikNusantara, a logistics company, decides to migrate all its operational data, including supplier contracts and shipment tracking records, to a public cloud service to cut costs. The IT team migrates within two weeks without conducting a formal risk assessment or notifying top management. Six months later, the cloud provider suffers a regional outage lasting 18 hours, halting all operations. Upon investigation, it is found that there was no business continuity plan, no supplier security evaluation, and no backup system in place.

Questions on next slide →

CASE 3 – Questions for Students

1. What ISO 27001 clause requires the organisation to conduct a risk assessment before implementing significant changes?

2. Which Annex A controls govern supplier relationships and cloud service security?

3. What clause and controls address business continuity and backup of information?

Good Luck!

Read ISO 27001 and apply your knowledge to the activities above.